

USDT0 · SECURITY REVIEW

USDT0

Canary Chain Configs Tx Verifications.

A security review of Canary Chain Configs Tx Verifications.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
USDT0	Canary Chain Configs Tx Verifications	Guardian	April 20 – May 5, 2026	May 12, 2026

§ 00

Contents.

13 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 4 findings	P. 08
§ 05	Disclaimer	P. 12
§ 06	About Guardian	P. 13

§ 01

Overview.

Guardian reviewed Canary Chain Configs Tx Verifications across a single review round. The final report includes 4 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	Everdawn-Labs/usdt0-oft-contracts
CLIENT	METHODOLOGY
USDT0	Smart contract · Manual · Main Review
PROJECT	
Canary Chain Configs Tx Verifications	
PREPARED BY	
Guardian	
AUDIT WINDOW	
April 20 – May 5, 2026	
FINAL REPORT	
May 12, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	0	0	0	0	0
Informational	4	0	4	0	0
All severities	4	0	4	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Canary Chain Configs Tx Verifications in `Everdawn-Labs/usdt0-oft-contracts`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
I-01	XAUT0 BSC-Conflux canary configs omitted	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 8
I-02	Hyperliquid TOKEN Safe owner mismatch	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 9
I-03	TON remains a documented two-DVN Solana pathway outside the Canary rollout	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 10
I-04	Monad enforced options use generic gas instead of the XAUT config	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 11

INFORMATIONAL **I-01**

ACKNOWLEDGED

XAUTO BSC-Conflux canary configs omitted

CATEGORY Warning
LOCATION canary-2.json
REVIEW Main Review

DESCRIPTION

`canary-2.json` does not include the XAUTO LayerZero ULN config updates for the live BSC <-> Conflux peer pair. The Safe transactions for BSC and Conflux exist and replay successfully, but the decoded `canary-2-xaut0` payload has no row for BSC source EID `30102` to Conflux destination EID `30212`, and no row for Conflux source EID `30212` to BSC destination EID `30102`.

This is not an unsupported route. Live peer checks returned `true` for BSC XAUTO recognizing Conflux and for Conflux XAUTO recognizing BSC. After replaying all submitted Safe calldata on local forks, the BSC and Conflux fork tests both failed with `assertion failed: 2 != 3`. The failure happened after the expected confirmations matched, so the stale value is the required DVN count. BSC -> Conflux and Conflux -> BSC remain at two required DVNs while the other canary-updated XAUTO routes move to three required DVNs.

If the batch is approved as-is, the XAUTO BSC <-> Conflux peer pair will keep weaker pre-canary ULN requirements while the rest of the XAUTO mesh is updated to include the canary DVN. That leaves one live peer pair inconsistent with the intended post-canary security model.

RECOMMENDATION

Add Safe calldata that updates both missing XAUTO ULN configs before approving or executing the batch: BSC source EID `30102` to Conflux destination EID `30212`, and Conflux source EID `30212` to BSC destination EID `30102`.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Hyperliquid TOKEN Safe owner mismatch

CATEGORY Warning
LOCATION –
REVIEW Main Review

DESCRIPTION

The Hyperliquid TOKEN verifier rerun reached the real governance checks and failed only the Safe owner-set check. The TOKEN proxy owner and ProxyAdmin owner both point to the expected Safe, `0xb64a89ad247a2d691a728bb6822a85eadd7fc541`, and the Safe threshold matches the expected value of 3. However, `getOwners()` does not match the verifier's expected signer set.

The expected owner set includes `0x1a6362ad64ccff5902d46d875b36e8798267d154`, but that address is missing from the live Hyperliquid TOKEN Safe. The live Safe instead includes `0x00f6d2b4b69ce697f913da16a9d73283dc4c78f2`, which is not part of the verifier's expected set for this check.

TOKEN/hyperliquid
Safe: `0xb64a89ad247a2d691a728bb6822a85eadd7fc541`
Failed check: `safe_owners`
Missing owner: `0x1a6362ad64ccff5902d46d875b36e8798267d154`
Extra owner: `0x00f6d2b4b69ce697f913da16a9d73283dc4c78f2`

RECOMMENDATION

Confirm which signer set is intended for the Hyperliquid TOKEN Safe.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-03

ACKNOWLEDGED

TON remains a documented two-DVN Solana pathway outside the Canary rollout

CATEGORY Warning
LOCATION –
REVIEW Main Review

DESCRIPTION

The local LayerZero config explicitly defines the Solana to TON XAUT0 connection with only two required DVNs: LayerZero Labs and USDT0. The live Solana state matches that documented configuration. This is not a live/config mismatch and it is not a missing-wiring issue: TON is already wired/configured with peer, nonce state, send/receive libraries, send/receive ULN configs, executor config, and enforced options.

The gap is that the current signer scope is described as a Canary DVN add for bringing Solana pathways online, but the scoped Squads bundle only upgrades Stable, BSC and Monad to the three-DVN set. TON remains a supported Solana pathway in `layerzero-xaut0.config.ts`, but proposals #47, #50 and #54-#66 do not target TON and therefore leave it on the documented two-DVN LayerZero + USDT0 configuration.

RECOMMENDATION

Clarify the intended TON policy before signers treat this bundle as complete Canary coverage for Solana-supported pathways. If TON should receive the same Canary quorum as Stable, BSC and Monad, add explicit Solana proposals to update the TON send ULN and receive ULN required DVNs and verify executor/enforced-options coverage. If TON is intentionally excluded, document that exclusion in the signer scope and local config comments so the two-DVN TON pathway is not mistaken for an omitted part of the Canary rollout.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-04

ACKNOWLEDGED

Monad enforced options use generic gas instead of the XAUT config

CATEGORY	Warning
LOCATION	layerzero-xaut0.config.ts
REVIEW	Main Review

DESCRIPTION

The XAUT config defines `MONAD_ENFORCED_OPTIONS` with `240000` gas for `send`, `sendAndCall` `lzReceive`, and `sendAndCall` compose execution. The Solana to Monad connection uses those Monad-specific enforced options in the connection tuple.

Scoped Squads proposal #66 does not apply those values. It decodes to the generic EVM options used by Stable and BSC: `send` `lzReceive` gas `200000`, `sendAndCall` `lzReceive` gas `100000` and `sendAndCall` compose gas `100000`. The transaction simulation passes because the program accepts the values, but the resulting Solana XAUT0 Monad peer would not match the gas settings defined by `layerzero-xaut0.config.ts`.

Consequently, approving #66 as-is would configure the Monad route with lower enforced execution gas than the XAUT config specifies. If Monad requires the higher gas values encoded in `MONAD_ENFORCED_OPTIONS`, Solana-originated XAUT0 messages to Monad can be underfunded for destination execution.

RECOMMENDATION

Replace proposal #66 with a `SetEnforcedOptions` transaction that matches `MONAD_ENFORCED_OPTIONS` or update `layerzero-xaut0.config.ts` and the signer scope if the generic values are intentional for Solana to Monad. Re-run the Squads decode, exact simulation and post-safe-txs model after the replacement.

RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.